

(d) Mapeo detallado de métricas CTEM GQM a requisitos normativos

Métrica	Descripción	Objetivo nacional (ONx)	NIS2 (art./anexo)	DORA (art.)	ISO 27001 (control)	NIST CSF (func./cat.)	Comentario de alineamiento
M1.1	% activos críticos inventariados en CTEM	ON1	Art. 21(2) (a) (identificación de activos y riesgos)	Art. 6(2), Art. 8(1)	A.5.9, A.5.10, A.5.12	ID.AM	Inventario de activos esenciales, base de gestión de riesgos exigida por NIS2/DORA.
M1.2	% activos críticos con descubrimiento continuo	ON1	Art. 21(2) (d) (medidas técnicas y operativas)	Art. 8(2)	A.8.8, A.8.9	ID.RA, PR.IP	Demuestra capacidades de monitorización continua y gestión de vulnerabilidades.
M1.3	% organizaciones con programa CTEM en activos críticos	ON1	Art. 20–21 (gobernanza y gestión de riesgos)	Art. 5–6	A.5.1, A.5.2	ID.GV	Señaliza el grado de implementación de programas estructurados de riesgo.
M2.1	Nº rutas de ataque explotables por activo crítico	ON1/ON2	Art. 21(2) (c)(d)	Art. 8(2), 24	A.8.28, A.8.29	ID.RA, PR.IP	Conecta análisis técnico de rutas de ataque con obligaciones de mitigación.

M2.2	% exposicion es críticas con amenaza activa	ON1/ON2	Art. 21(2) (c)	Art. 8(2)	A.5.7, A.5.25	ID.RA	Uso de ciberinteli gencia para priorizar riesgos según NIS2 y buenas prácticas ENISA.
M2.3	Densidad de exposicion es críticas por activo crítico	ON1	Art. 21(2) (c)	Art. 6(6)	A.8.28	ID.RA	Mide concentra ción de riesgos en activos clave, útil para priorizaci ón supervisor a.
M3.1	% exposicion es críticas cerradas dentro del SLA	ON2	Art. 21(2) (d)	Art. 8(6)	A.8.8, A.8.21	PR.IP, RS.MI	Evidencia la eficacia de medidas de mitigació n y mejora continua.
M3.2	MTTR de exposicion es críticas	ON2	Art. 21(2) (d)	Art. 11	A.6.1, A.8.8	PR.IP, RS.MI	Mejora de tiempos de respuesta, relevante para informes a regulador es.

M3.3	Variación mensual del índice de exposición en activos críticos	ON2	Art. 21(2) (c)(d)	Art. 6(6)	A.5.29	ID.RA, PR.IP	Mide evolución del riesgo residual, demandado por supervisores y auditores.
M4.1	% exposiciones críticas validadas como explotables	ON2/ON3	Art. 21(2) (e)(f)	Art. 24-27	A.5.23, A.8.29	PR.IP, DE.DP	Vincula pruebas de seguridad con evaluación de riesgos efectivos.
M4.2	% escenarios adversariales donde fallan controles	ON2/ON3	Art. 21(2) (e)(f)	Art. 24-27	A.5.23, A.8.30	PR.IP, DE.DP, RS.TE	Orientado a pruebas de resiliencia y robustez de controles.
M4.3	Tiempo medio en implementar mejoras de control	ON2/ON3	Art. 21(2) (d)(f)	Art. 11, Art. 24	A.5.30	RS.MI	Refleja madurez del ciclo de mejora tras pruebas y auditorías.
M5.1	Tiempo medio de recuperación de servicios esenciales	ON3	Art. 23-24	Art. 11-13	A.5.29, A.8.4	PR.PT, RS.RP	Mide resiliencia y continuidad de servicios esenciales.

M5.2	% incidentes con interrupción significativa	ON3	Art. 23	Art. 11–13	A.5.29	RS.AN, RC	Útil para supervisión sectorial de impacto en servicios esenciales.
M5.3	Reducción interanual de incidentes con interrupción significativa	ON3	Art. 23–24	Art. 13	A.5.29, A.5.30	RS.CO, RC	Mide resultados de programas de resiliencia a medio plazo.
M6.1	% entidades reguladas que incluyen CTEM en informes	ON4	Art. 20–23	Art. 4–15	A.5.5, A.5.7	ID.GV, RS.CO	Alineamiento entre reporting CTEM y obligaciones de información.
M6.2	% entidades que usan NIST/ISO/MITRE para CTEM	ON4	Art. 21(2) (b)	Art. 6(1)	A.5.1, A.5.2	ID.GV	Fomenta estandarización, comparabilidad y uso de buenas prácticas.
M6.3	Tiempo medio de notificación y calidad de incidentes	ON4	Art. 23–24	Art. 19–20	A.5.25	RS.CO	Relaciona CTEM con exigencias de notificación oportuna y completa.